Exposición · Grupo 2 - AuthN / AuthZ (OAuth / JWT)

Sistemas Distribuidos · Lic. en Sistemas · IDEI · UNTDF

Cátedra de Sistemas Distribuidos

Cómo se arma la exposición

Cada grupo toma su tema y lo presenta en **dos partes**:

1. **El resumen teórico (unos 8-10 min).** Expliquen **qué problema** resuelve el tema y los **conceptos** de los subtemas que marcamos, a un nivel que la clase entienda. No es un repaso exhaustivo ni hay que cubrir todo lo que existe sobre el tema: alcanza con que quede claro **el porqué** y las **ideas centrales**. Piensen que se lo están explicando a un compañero que no lo vio.
2. **La demo (máx. 5 min).** Una **herramienta funcionando en vivo** sobre una VM del TP1. **No hace falta una aplicación grande**: un montaje mínimo que muestre el concepto y **al menos un modo de falla o un trade-off** (qué pasa cuando algo se cae, se satura o se usa mal). Ese "qué mostrar" es lo que se corrige, no la herramienta en sí.

Duración total: 15-20 min + preguntas. **Entregable:** slides + la demo lista (en vivo o grabada como respaldo). Ensayen la demo antes: 5 minutos se van rápido, dejen todo precargado.

En cada guía marcamos, además de los subtemas, **qué se pretende** en el teórico y **qué alcanza** para la demo, así no quedan dudas de hasta dónde llegar.

> Consejos para la demo corta
>
> - Arrancá con el "antes": el estado inicial, para que se note el cambio.
> - Un solo camino feliz + una sola falla. No intenten mostrar todo.
> - Tengan los comandos en un archivo listo para pegar; nada de tipear en vivo largo.
> - Si algo depende de red o descarga, téngalo cacheado o grabado.

Grupo 2 - AuthN / AuthZ (OAuth / JWT) · orden 6

Integrantes: Araya, Lucas Ezequias · Benedetti, Constanza

Herramienta: Keycloak

La idea: distinguir **quién sos** (autenticación) de **qué podés hacer** (autorización), con **tokens firmados** que viajan entre servicios.

En el teórico se pretende que quede clara la diferencia entre **autenticar** y **autorizar**, y qué es un **token firmado** (JWT) que otros servicios pueden **validar** sin volver a preguntar. Subtemas:

- **AuthN vs AuthZ**: identidad vs permisos.
- **OAuth2 / OIDC**: flujos de login, clientes, roles.
- **JWT**: *claims*, **firma**, expiración y **validación** en el servicio (por qué otro servicio puede confiar sin volver a preguntar).
- **SSO**: un **único** login sirve para **varias** apps (sesión compartida en el proveedor de identidad).

Para la demo armen el **SSO más simple posible**: dos apps -**App A** y **App B**- registradas como clientes en el **mismo *realm*** de Keycloak. Mostrar:

- Entrar a **App A** sin sesión → te **redirige a Keycloak** a identificarte.
- Ya identificado, entrar a **App B** → **no** te vuelve a pedir login (misma sesión SSO). **Ese es el corazón del SSO:** un solo login sirve para las dos.
- **Autorización con un rol simple:** definí un rol (por ejemplo `acceso-b`) y hacé que **App B** lo **exija**. Un usuario **sin** el rol entra a App A pero **App B lo rechaza**; con el rol, entra a las dos.

> Tip
>
> No hace falta programar dos apps: alcanzan dos páginas protegidas (por ejemplo con un *oauth2-proxy* o el adaptador de Keycloak delante de cada una). Lo que importa es que se **vea** el login único y el rol filtrando.

Qué se evalúa: que un **solo login** sirva para **las dos apps** (SSO), y que un **rol** decida el acceso a cada servicio (autorización).

Rúbrica breve (para todos)

Se corrige, en partes iguales:

- **Marco teórico**: claridad del resumen y de los subtemas; que expliquen **el problema**, no solo la herramienta.
- **Demo**: que **funcione** y se entienda; el **camino feliz** y **el modo de falla / trade-off**.
- **Criterio**: por qué esta herramienta, qué **cuesta** y cuándo **no** la usarían.
- **Tiempo y presentación**: respetar los 15-20 min y los 5 de demo; reparto entre integrantes.